Relatório técnico - NexaHome Lab S1

Data: 11 de novembro de 2026. Objeto: dispositivo IoT educacional simulado em Node.js, versão 1.0. Ambiente: um único computador, rede loopback 127.0.0.1). Natureza da evidência: execução local reproduzível; não houve análise de equipamento físico.

1. Dispositivo, componentes e arquitetura

O NexaHome Lab S1 declara MCU virtual de 32 bits, flash virtual de 512 KiB e sensor de temperatura virtual. A imagem NHFW contém um manifesto JSON; a saída UART é simulada por log; o firmware gera telemetria JSON transmitida por TCP a um coletor local. Não existe placa, fonte, barramento elétrico ou serviço externo. O diagrama validado está em architecture/architecture.md.

MCU/flash/sensor virtuais -> imagem NHFW -> log UART simulado

?-> TCP loopback -> coletor local

2. Superfície de ataque e metodologia

As superfícies efetivamente testadas foram: arquivo de imagem, log UART simulado e mensagem TCP local. O script criou uma imagem original, copiou-a, comparou SHA-256, analisou a cópia, executou cliente/coletor TCP e verificou seis condições. O acesso ao arquivo/log e ao host local é pré-requisito para as exposições observadas. Ferramentas: Node.js 24.18.0 e módulos nativos crypto, fs, net. Procedimento exato em findings/controlled-demo.md.

3. Preservação e análise do firmware

Origem: src/lab-assessment.mjs, criado para o laboratório. Nome: nexahome-lab-s1-v1.0.bin; tamanho: 345 bytes; SHA-256 original/cópia: 09883d6e34b1e03d7084c7515db37d16b0273ef99a6d1dd28bdaa2ddc0f7b00e. A imagem original ficou em out/private/original/, a cópia em out/private/work/, ambas excluídas do Git. O cabeçalho NHFW inicia no offset 0, o comprimento little-endian no offset 4, e o manifesto JSON de 337 bytes no offset 8. Não há partições, sistema de arquivos, bibliotecas ou código de MCU. O campo token contém LAB-ONLY-KEY-7C2A, credencial fictícia. Evidências: evidence/simulation/hashes.txt e firmware-analysis.txt.

4. Interfaces físicas

Não há interfaces físicas no simulador. O log UART simulado mostrou DEBUG enrollment token=LAB-ONLY-KEY-7C2A na inicialização (evidence/simulation/uart-observation.txt). Isso comprova a exposição no log simulado. A existência e proteção de UART/JTAG/SPI/I²C em equipamento comercial não foram avaliadas. Se uma versão real emitisse tal informação por UART acessível, o risco dependeria de acesso físico, privilégio do token e controles da interface.

5. Comunicações

O cliente enviou JSON por TCP a 127.0.0.1, porta efêmera. O coletor recebeu exatamente os bytes enviados, incluindo device_id, temperatura e token fictício (evidence/simulation/network-observation.txt). TLS e autenticação do coletor não estão implementados. A evidência é transcrição de aplicação, não PCAP nem interceptação por terceiros. Identificar TCP/JSON descreve formato; julgar segurança requer examinar autenticação, proteção do canal, alcance e sensibilidade dos campos.

6. Demonstração controlada

Executar node src/lab-assessment.mjs; verificar status: PASS, igualdade de hashes e presença do token na imagem, log e payload. As seis verificações de evidence/simulation/checks.json passaram. A demonstração é local, reproduzível e não acessou serviços externos.

7. Achados, riscos e mitigação

Impacto e probabilidade referem-se ao laboratório. Impacto baixo porque o token não concede acesso real; probabilidade alta porque as condições foram reproduzidas de modo determinístico; pela matriz adotada, risco médio.

ID | Evidência | Fragilidade / ameaça contextual | Impacto | Prob. | Risco | Mitigação

F01 | firmware-analysis.txt, campo token | Quem obtiver a imagem lê o token | Baixo | Alta | Médio | Credencial individual e armazenamento protegido

F02 | uart-observation.txt, linha 3 | Quem lê o log vê o token | Baixo | Alta | Médio | Remover segredos de logs de produção

F03 | network-observation.txt, checks.json | Payload em texto claro; exposição se o fluxo for acessível | Baixo | Alta | Médio | Canal protegido e autenticação de pares

F01 e F02 se relacionam à proteção de dados e controle de interfaces da NIST IR 8259A (https://csrc.nist.gov/pubs/ir/8259/a/final). F03 se relaciona à proteção de parâmetros críticos em trânsito da ETSI EN 303 645, seção 5.5 (https://www.etsi.org/deliver/etsi_en/303600_303699/303645/03.01.03_60/en_303645v030103p.pdf).
A lista de "referências indicadas" no enunciado não foi fornecida; confirmar se estas são aceitas.

8. Hardening comercial

Priorizar: credenciais únicas por unidade, não registrar segredos, TLS com autenticação de pares, mínimo privilégio, debug controlado, atualização assinada, proteção contra rollback e recuperação de falha. Secure Boot e proteção de armazenamento dependem do hardware. O plano completo e critérios de verificação estão em remediation/hardening-plan.md.

9. Exemplo real pesquisado

O relatório NSTAC hospedado pela CISA (https://www.cisa.gov/sites/default/files/publications/NSTAC%20Report%20to%20the%20President%20on%20ICR%20FINAL%20%2810-12-17%29%20%281%29-%20508%20compliant_0.pdf) descreve o botnet Mirai explorando dispositivos IoT com configurações padrão e credenciais embutidas, e o ataque DDoS à Dyn em 2016. A relação com F01 é analogia de projeto, não afirmação de que o simulador esteja vulnerável ao Mirai.

10. Limitações

Este estudo não prova segurança ou insegurança de um dispositivo comercial. A "firmware" não é executável em MCU; não houve análise elétrica, PCAP, interceptação de rede, serviço em nuvem ou testes de atualização. Se a disciplina exigir hardware físico ou firmware real, este caso precisa ser substituído ou complementado.